

Information Security Governance - Week 1 Practical Laboratory

Task 1 Governance Blueprint

Executive request: The CEO requires a formal security governance structure with clear roles, reporting relationships and accountability following the recent near-miss.

Current Organisational Context

Employee / Role	Department	Relevant Context
John Smith – IT Manager	IT Operations	Manages infrastructure and performs some security activities.
Jane Doe – Senior Developer	Development	Leads a key product development team.
Mark Johnson – Compliance Officer	Legal & Compliance	Focuses on healthcare regulatory obligations.
Emily White – Data Analyst	Finance	Handles sensitive financial information.
Robert Green – HR Manager	Human Resources	Owns onboarding and offboarding processes.

Required Evidence Task 1

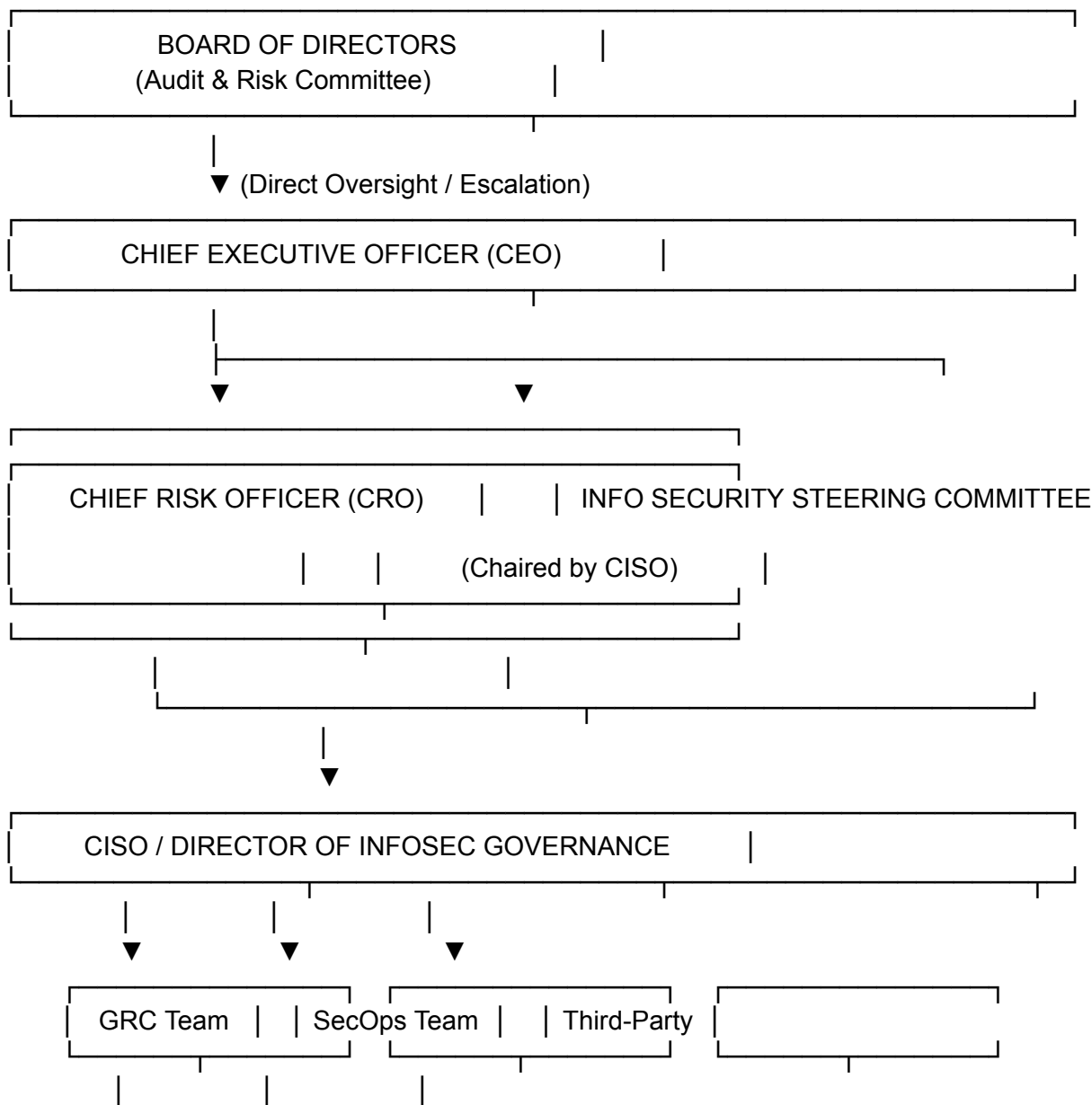
1. A current-state governance gap assessment identifying the most important weaknesses in GHC's ad-hoc model.
2. A proposed security governance organisational chart showing the Board, CEO, governance function and relevant business/technology relationships.
3. A RACI matrix covering at least six governance activities, including policy approval, risk review and incident response planning.

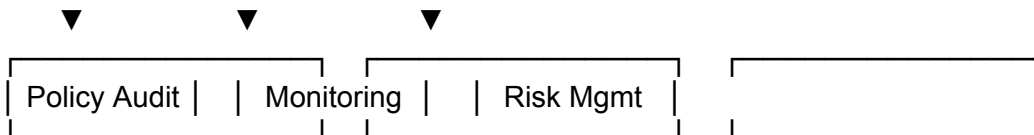
4. A short explanation of how the proposed structure supports accountability, transparency, business alignment and risk management.

Response To TASK 1: Information Security Governance Structure & Alignment Design

1. Target Operating Model & Reporting Hierarchy

To resolve GHC’s structural conflict of interest, where security decisions were previously subordinated under operational IT priorities, the Chief Information Security Officer (CISO) / Director of Information Security Governance will report directly to the Chief Executive Officer (CEO) and maintain an independent escalation channel to the Board Audit & Risk Committee.





2. Detailed RACI Matrix for Core Governance Functions

- R – Responsible: The role that performs the activity.
- A – Accountable: The sole role with final approval and decision-making authority.
- C – Consulted: Subject matter experts who provide key input prior to execution.
- I – Informed: Roles kept updated on progress or outcomes.

Key Governance Function / Activity	Board / Audit Comm.	CEO	CISO / Dir. InfoSec	CIO / IT Ops	Legal & Compliance	Business / HR Leads
Enterprise Security Policy Approval	A	C	R	C	C	I
Information Security Charter Authorization	A	A	R	C	C	C
Information Risk Appetite & Tolerance Definition	A	C	R	C	C	C
Exception & Risk Acceptance Approvals (High/Critical)	I	A	R	C	C	I

Security Incident Escalation (Severity 1 Data Leakage)	I	A	R	C	C	I
Regulatory & Healthcare Compliance Monitoring	I	I	R	C	A	C
Vendor Security Assessment (Acquisitions & Cloud)	I	I	R	C	C	C
Security Awareness Training Enforcement	I	I	R	C	C	A

Task 2 Information Security Charter

The CFO and Board require a formal mandate for the information security programme. Draft a concise but complete Information Security Charter that can be approved by executive management and referenced across the organisation.

GHC Strategic Goals for 2026

Strategic Goal	Business Intent
----------------	-----------------

Expand Market Share	Increase the client base by 25% through new features and entry into two regional markets.
Enhance Operational Efficiency	Reduce overhead by 10% and improve system uptime to 99.99%.
Maintain Customer Trust	Protect patient information and aim for zero major data breaches.
Foster Innovation	Invest in AI-driven diagnostics and secure data-exchange capabilities.
Achieve Regulatory Excellence	Meet applicable healthcare and data-protection obligations proactively.

Charter Sections

- Purpose — why the Information Security Programme exists and how it supports GHC.
- Scope — assets, systems, data, people and third parties covered by the programme.
- Authority — source of authority, decision rights and escalation powers.
- Roles and Responsibilities — high-level governance accountabilities linked to Task 1.
- Key Principles — risk-based, business-aligned, proportionate and continuously improving security.
- Reporting Structure — management, committee and Board reporting expectations.
- Review and Approval — approval authority, review frequency and change control.

Required Evidence Task 2

5. Completed GHC Information Security Charter.
6. A 1–2 paragraph justification memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions.

Response To Task 2 - Information Security Charter

GlobalHealth Connect (GHC)

Official Corporate Enterprise Mandate

Document Ref: GHC-CHARTER-SEC-2026-V1

1. Purpose

The Information Security Programme exists to protect GlobalHealth Connect's (GHC) information assets, cloud based patient management platforms, and healthcare data ecosystem from evolving cyber threats, operational disruptions, and unauthorized exposure. By establishing an enterprise wide security framework, the Programme ensures that security operates as a business enabler, safeguarding patient trust, maintaining continuous service availability, protecting intellectual property, and supporting GHC's strategic growth, innovation, and regulatory compliance goals.

2. Scope

This Charter applies universally across all operations within GHC. The scope explicitly encompasses:

- Assets and Infrastructure: All cloud environments, physical hardware, networks, data centers, databases, and endpoints owned, managed, or leased by GHC.
- Systems and Software: All patient management systems, web applications, internal operational software, and emerging AI-driven diagnostic platforms.
- Data: All Protected Health Information (PHI), Personally Identifiable Information (PII), proprietary source code, corporate financials, and operational data across its entire lifecycle (in transit, at rest, and in processing).
- People and Entities: All full time, part time, and temporary employees, executive leadership, contractors, and all newly acquired subsidiaries.
- Third Parties: All third party cloud service providers, software vendors, business associates, and external partners connected to GHC networks or processing GHC data.

3. Authority

The Information Security Programme derives its authority directly from the Board of Directors and the Chief Executive Officer (CEO). Under this mandate, the Director of Information Security Governance / CISO is granted explicit authority to:

- Develop, implement, and enforce information security policies and controls across all GHC divisions and acquired companies.

- Halt any business operation, system deployment, or third party integration that poses an unmitigated, critical threat to patient safety or data confidentiality.
- Conduct unannounced technical compliance audits, vulnerability scans, and security assessments on all corporate systems.
- Access all technical logs, system records, and incident data necessary to investigate security breaches and ensure operational resilience.

4. Roles and Responsibilities

- Board of Directors (Audit and Risk Committee): Maintains ultimate fiduciary oversight of information security risks, approves the Enterprise Security Charter, and reviews quarterly strategic risk profiles.
- Chief Executive Officer (CEO): Retains executive accountability for enterprise risk, authorizing security budgets and enforcing cross departmental compliance.
- Director of Information Security Governance (CISO): Leads the strategy, design, execution, and continuous monitoring of the security governance programme, serving as the primary advisor to the Board and CEO on cyber risk.
- Chief Information Officer (CIO) / IT Operations: Responsible for implementing technical security controls within infrastructure pipelines and maintaining system availability SLAs.
- Information Security Steering Committee (ISSC): Provides cross functional oversight, aligns security initiatives with business units, and evaluates policy exceptions.
- Department Heads and Business Unit Leads: Accountable for enforcing security policies within their respective teams and ensuring 100% staff completion of security training.
- All Employees and Contractors: Responsible for adhering to security policies, completing mandatory security awareness training, and reporting suspicious activities or incidents immediately.

5. Key Principles

The GHC Information Security Programme operates under five core principles:

1. Risk Based Security: Controls are selected and deployed based on formal risk evaluations, prioritizing protection where business impact and threat exposure are highest.

2. Business Aligned Enabler: Security strategies directly support business expansion, cloud scalability, and product innovation without creating unnecessary operational friction.
3. Proportionate Protection: Security measures are balanced, cost effective, and tailored to the sensitivity of the data and systems being protected.
4. Security and Privacy by Design: Security requirements, zero trust architectures, and healthcare compliance controls are embedded into product development and corporate acquisitions from day one.
5. Continuous Improvement: Security controls, policy frameworks, and incident response capabilities are continually assessed, tested, and optimized to adapt to emerging threats.

6. Reporting Structure

- Management and Operational Reporting: The CISO maintains regular operational reporting to the CEO and collaborates closely with the CIO, Legal Counsel, and Business Unit Heads through monthly Steering Committee sessions.
- Committee Oversight: The CISO chairs the monthly Information Security Steering Committee (ISSC) to track security KPIs, policy compliance, and risk treatment plans.
- Executive and Board Reporting: The CISO provides formal quarterly cybersecurity updates to the Board Audit and Risk Committee. Critical security incidents (Severity 1 / material data breaches) trigger an immediate, automated escalation to the Board Chair and CEO within 1 hour.

7. Review and Approval

- Approval Authority: This Charter must be formally approved by the CEO and the Chair of the Board Audit & Risk Committee.
- Review Frequency: Reviewed annually by the Director of Information Security Governance and the ISSC to ensure continued alignment with GHC's strategic direction and regulatory changes.
- Change Control: Any material revisions or structural changes to this Charter require formal re-approval by the Executive Leadership Team and the Board.

Authorized and Approved by:

Chief Executive Officer, GlobalHealth Connect

Date: September 11, 2026

Chair, Board Audit & Risk Committee

Date: September 11, 2026

MEMORANDUM

TO: Marcus Thorne, Chief Financial Officer

FROM: Director of Information Security Governance

DATE: September 11, 2026

Justification of the Information Security Charter in Support of GHC's 2026 Strategic Goals

Dear Marcus,

The attached Information Security Charter transitions GlobalHealth Connect from a reactive, ad-hoc IT security posture into a structured, business aligned governance programme. By establishing a clear executive mandate, this Charter directly underpins GHC's 2026 strategic objectives. It protects our goal to Maintain Customer Trust and Achieve Regulatory Excellence by codifying zero tolerance data protection baselines and ensuring proactive compliance with HIPAA and regional data privacy laws. Furthermore, it supports our growth ambitions to Expand Market Share and Foster Innovation by embedding a Security by Design framework into our product development and acquisition pipelines. This ensures that new features, AI-driven diagnostic tools, and acquired entities can be integrated safely without exposing our core cloud database to cross contamination or breach related downtime.

From an investment and accountability perspective, this Charter gives your office and the Board the structural clarity needed to make sound financial decisions. It replaces arbitrary IT spending with a risk based resource allocation model, ensuring every dollar spent on security is tied directly to quantified risk reduction and operational efficiency (supporting our 99.99% system uptime target). By

defining clear governance roles through a RACI framework and establishing mandatory risk acceptance escalation thresholds, the Charter ensures that business unit leaders take explicit ownership of their operational risk profiles rather than treating security as an unmonitored IT expense. This formal mandate provides the defensible oversight required to protect executive leadership, reassure institutional investors, and secure GHC's long-term financial health.

Task 3 Board Reporting and Security Metrics

The Board has requested a concise, business-focused security update. Select the most decision-useful metrics from the six-month dataset, interpret the trends and present the organisation's security posture without unnecessary technical jargon.

Month	Phishing	Malware	Critical Vulns Patched	Patching %	Training %	High-Risk Incidents
September	150	25	10 of 15	67%	45%	2
October	180	30	12 of 20	60%	50%	3
November	210	35	15 of 25	60%	55%	4
December	250	40	18 of 30	60%	60%	5
January	280	45	20 of 35	57%	65%	6
February	320	50	22 of 40	55%	70%	7

Required Evidence Task 3

7. A one-page Board Executive Summary containing an overall Red/Amber/Green posture assessment and justification.
8. Five selected security metrics showing current status, six-month trend and concise business commentary.
9. At least two priority risks/issues and two actionable recommendations.
10. A short rationale explaining why your five selected metrics are suitable for Board oversight.

Response To TASK 3: Executive Board Metrics & Dashboard Design

BOARD EXECUTIVE SUMMARY

To: Board of Directors, GlobalHealth Connect (GHC)

From: Director of Information Security Governance

Date: September 11, 2026

Subject: Six Month Information Security Posture and Metrics Analysis

1. Overall Security Posture Assessment: AMBER (HIGH EXPOSURE)

Justification:

GHC’s overall security posture is assessed as AMBER. While employee participation in security training has steadily improved over the last six months, our operational risk exposure is widening at an alarming rate. External threat activity (phishing and malware attacks) has more than doubled, which directly correlates with a continuous rise in high risk security incidents (from 2 in September to 7 in February). This exposure is driven primarily by a widening gap in our technical defenses: despite patching more total vulnerabilities each month, our overall patching completion rate has dropped from 67% to 55%. In a cloud based healthcare environment processing Protected Health Information (PHI), leaving 45% of critical vulnerabilities unpatched creates an unacceptable risk of a major data breach and regulatory penalties under HIPAA and GDPR.

2. Selected Security Metrics Dashboard & Business Commentary

METRIC	SEP	FEB	6-MONTH TREND	BUSINESS COMMENTARY & RISK IMPACT
High-Risk Incidents	12	7	+250%	[Degrading] Operational threat levels are rising sharply, straining incident response capabilities and threatening uptime.
Vulnerability Patching %	87%	55%	-12%	[Degrading] Backlog of unpatched critical flaws is growing faster than IT can deploy fixes, expanding our breach surface.
Phishing Attack Volume	150	320	+113%	[Degrading] GHC is experiencing significantly more targeted social engineering attacks, testing our human firewall daily.
Security Training %	45%	70%	+25%	[Improving] Strong positive adoption of security culture, though still short of our 100% mandatory compliance target.
Malware Detections	25	50	+100%	[Degrading] Endpoint threat volume has doubled, indicating increased exposure from new integrations and user interactions.

3. Priority Risks & Actionable Recommendations

Priority Risks / Issues

1. Accumulating Critical Vulnerability Backlog: IT Operations is failing to keep pace with incoming software vulnerabilities. Unpatched critical vulnerabilities grew from 5 in

September to 18 in February. This unmanaged backlog represents the single largest threat of a catastrophic system compromise or ransomware outbreak.

2. Accelerating High Risk Incident Escalation: High-risk incidents have increased by 250% over six months. This indicates that external attack volume (phishing/malware) is successfully breaching perimeter controls and requiring manual containment by security staff.

Actionable Recommendations

1. Implement Mandatory Vulnerability Remediation SLAs: Establish strict policy-enforced Service Level Agreements requiring IT Operations to patch all critical vulnerabilities within 72 hours of release. Mandate that unpatched critical vulnerabilities past SLA escalate directly to the CISO and CEO.
2. Deploy Automated Email & Endpoint Threat Protection: Upgrade perimeter security tools to automatically filter advanced phishing attempts and isolate malware endpoints before they require manual incident response intervention, mitigating the rise in high-risk events.

4. Rationale for Selected Metrics

The five selected metrics were chosen because they tell a complete, business focused story of GHC's risk landscape without bogging the Board down in low level technical logs:

- High Risk Incidents (Outcome Metric): Measures actual business impact and security failures, providing the Board with direct visibility into operational resilience.
- Patching Percentage (Control Effectiveness Metric): Shows whether our technical defenses are keeping up with system growth and external threats, rather than just tracking raw volume.
- Phishing and Malware Volumes (Threat Landscape Metrics): Quantifies the external environment GHC operates in, helping the Board understand why security investments must scale with company growth.
- Training Completion Percentage (Human Risk Metric): Measures organizational culture and workforce readiness, evaluating how effectively we are reducing the risk of human error.

Task 4 Security Steering Committee

A dispute has emerged between the CTO and IT Manager regarding a proposed password policy. The CTO believes the policy will create excessive friction; the IT Manager argues that stronger

controls are necessary. The CEO wants a formal Security Steering Committee (SSC) to resolve such cross-functional issues.

Conflict context: The proposed policy requires 16-character complex passwords changed every 30 days without password-manager integration. The CTO recommends a more balanced approach emphasising multi-factor authentication and secure password-management.

Required Evidence Task 4

11. Security Steering Committee Terms of Reference covering purpose, scope, membership, responsibilities, meeting cadence, decision authority and reporting.
12. A sample agenda for the first SSC meeting with the password-policy conflict as a key discussion item.
13. A 1–2 paragraph briefing note to the CEO explaining how the SSC will resolve cross-functional conflict and maintain strategic alignment.

Response To TASK 4: Security Steering Committee Charter (SSC) & Operating Model

SECURITY STEERING COMMITTEE (SSC) CHARTER & RESOLUTION BRIEFING

To: Chief Executive Officer, GlobalHealth Connect (GHC)

From: Director of Information Security Governance / CISO

Date: September 11, 2026

Subject: Task 4 Submission Security Steering Committee Governance Framework & Conflict Resolution

1. Security Steering Committee (SSC) — Terms of Reference

GlobalHealth Connect (GHC)
Security Steering Committee (SSC)
Official Terms of Reference
Document Ref: GHC-TOR-SSC-2026-V1

Purpose

The Security Steering Committee (SSC) is established as the principal executive governance body responsible for aligning GHC's information security strategy with core business objectives. The Committee ensures cross-functional oversight, balances security requirements against

operational efficiency, evaluates enterprise cyber risks, and serves as the official escalation and resolution body for security policy disputes across all GHC divisions and acquired subsidiaries.

Scope

The SSC's mandate covers all information security policies, technical controls, data privacy requirements, risk management strategies, and regulatory compliance obligations across GHC's cloud systems, corporate infrastructure, healthcare software platforms, and third party vendor relationships.

Membership & Governance Roles

- Committee Chair: Director of Information Security Governance (CISO) Sets agendas, facilitates sessions, and manages executive escalations.
- Executive Sponsor: Chief Executive Officer (CEO) / Chief Financial Officer (CFO), Provides executive oversight and strategic direction.
- Core Steering Members:

Chief Technology Officer (CTO) / Engineering Lead

IT Manager / Infrastructure & Operations Lead

Chief Risk Officer (CRO) / Risk Management Lead

General Counsel / Data Privacy Officer (DPO)

Head of Clinical Operations / Business Unit Representative

Chief Human Resources Officer (CHRO)

Key Responsibilities

- Policy Arbitration & Governance: Review, evaluate, and approve enterprise security policies, resolving conflicts between security controls and operational speed.
- Strategic Alignment: Ensure security initiatives directly support GHC's business goals, product innovation, and healthcare compliance mandates.
- Risk Appetite Management: Review top enterprise cyber risks, approve formal risk treatment plans, and evaluate high-risk exception requests.
- Resource Allocation: Prioritize security investments and review security program roadmap progress.
- Incident Oversight: Evaluate post-incident review reports for major security events to ensure systemic corrective actions are institutionalized.

Meeting Cadence and Quorum

- Cadence: Formal meetings occur monthly (60–90 minutes).
- Ad-Hoc Sessions: The Chair may call an Extraordinary Session within 24 hours to address critical policy deadlocks or major security incidents.
- Quorum Requirements: A valid meeting requires at least five core members present, including the Committee Chair (CISO), CTO (or engineering delegate), and General Counsel.

Decision Making and Escalation Authority

- **Consensus Driven Approvals:** The SSC strives for consensus on all policy decisions, evaluating risk using objective frameworks (e.g., NIST CSF / FAIR risk modeling).
- **Voting Mechanism:** If consensus cannot be reached, decisions pass by a simple majority vote among attending core members.
- **CEO Escalation Gate:** If a critical dispute directly impacts core business revenue, system availability SLAs, or overall regulatory standing, the CISO and CTO submit a joint briefing note to the CEO for final, binding determination.

Reporting Line

The SSC reports directly to the Chief Executive Officer and provides formal quarterly risk summaries to the Board Audit & Risk Committee.

2. Inaugural Security Steering Committee Meeting — Sample Agenda

GlobalHealth Connect (GHC)

Security Steering Committee; Inaugural Meeting

Date: September 18, 2026 | Time: 10:00am-11:30am EST | Location: BoardRoom/Virtual.

Chair : Director of InfoSec Governance (CISO)

Secretary : GRC Lead

- **10:00 AM – 10:10 AM | Welcome and Charter Formalization** (*Presenter: CISO*)
 - Introduction of members, review of the SSC Terms of Reference, and formal confirmation of voting protocols.
- **10:10 AM – 10:25 AM | Enterprise Threat Landscape & Q3 Risk Briefing** (*Presenter: CISO*)
 - Summary of recent metric trends (phishing volume, unpatched vulnerability backlog) and operational exposure across acquired entities.
- **10:25 AM – 11:05 AM | Key Discussion Item: Password Policy and Authentication Control Policy** (*Presenters: IT Manager & CTO*)
 - **10:25 AM – 10:35 AM:** Presentation of the proposed 16-character / 30-day rotation policy (IT Manager; Technical risk perspective).
 - **10:35 AM – 10:45 AM:** Presentation of the alternative MFA + Enterprise Password Manager framework (CTO; Operational friction & user experience perspective).
 - **10:45 AM – 11:05 AM:** Open Committee deliberation, threat modeling evaluation against NIST SP 800-63B standards, and final policy vote.
- **11:05 AM – 11:20 AM | Exception Governance & Acquired System Onboarding** (*Presenter: GRC Lead*)
 - Review of the risk acceptance workflow for legacy infrastructure from acquired subsidiaries.
- **11:20 AM – 11:30 AM | Action Items & Closing Remarks** (*Presenter: CISO*)
 - Assignment of policy rollout action items, confirmation of next meeting date, and meeting adjournment.

3. CEO Briefing Note: Conflict Resolution and Strategic Alignment

MEMORANDUM

TO: Chief Executive Officer, GlobalHealth Connect

FROM: Director of Information Security Governance / CISO

DATE: September 11, 2026

SUBJECT: Resolving Cross Functional Conflicts via the Security Steering Committee

The establishment of the Security Steering Committee (SSC) transitions GHC away from informal, siloed debates between technical teams into an objective, business aligned governance model. Disputes like the current password policy deadlock between the CTO and IT Manager occur when security controls are evaluated in isolation rather than against business impact and industry standards. The SSC resolves these friction points by providing a structured forum where the IT Manager’s risk concerns (preventing unauthorized system access) and the CTO’s operational priorities (reducing user friction and maintaining developer speed) are evaluated side by side using risk based data, specifically aligning our policies with modern standards like NIST SP 800-63B, which favor Multi-Factor Authentication (MFA) and secure password managers over disruptive 30-day password resets.

Beyond resolving individual policy deadlocks, the SSC ensures that security governance actively supports GHC’s broader strategic goals. By bringing together leadership from Engineering, IT, Legal, Risk, and Operations every month, the committee guarantees that security policies are proportionate, cost effective, and enforce clear accountability. Rather than positioning security as a blocker to innovation, the SSC acts as a strategic enabler, ensuring that rapid feature deployment and company growth occur within a clear, pre-approved risk framework that protects patient trust, ensures 99.99% system availability, and safeguards executive leadership.

Task 5 Governance Maturity Assessment

The Board wants evidence that the new governance arrangements will improve over time. Assess GHC's current maturity using the simplified 1–5 model below and propose a realistic roadmap to achieve at least Level 3 (Defined) across all domains within 12–18 months.

Current-State Interview Summary

Governance Domain	Current-State Evidence
Policy & Documentation	Policies are inconsistent, inherited from acquisitions and not always current.

Roles & Responsibilities	Security ownership and accountability are unclear.
Risk Management	The organisation is reactive and lacks a formal proactive assessment process.
Metrics & Reporting	Technical metrics exist, but they are not consistently translated into business impact.
Training & Awareness	Annual training is mandatory, but engagement is low.
Compliance	Preparation is audit-driven rather than continuously monitored.

Simplified Maturity Scale

Level	Description
1 – Ad Hoc	Informal, reactive and inconsistent; no defined processes.
2 – Initial	Some processes exist but are inconsistently documented or applied.
3 – Defined	Processes are documented, standardised, communicated and supported by clear responsibilities.
4 – Managed	Processes are measured, monitored and reviewed against performance targets.
5 – Optimising	Continuous improvement is embedded and processes adapt quickly to changing risk.

Required Evidence Task 5

14. A completed maturity assessment for Policy & Documentation, Roles & Responsibilities, Risk Management, Metrics & Reporting, Training & Awareness, and Compliance.

15. A 12–18 month maturity roadmap containing 3–5 priority initiatives. For each initiative, state the objective, key activities and measurable expected outcome.

16. A 1–2 paragraph executive summary to the Board explaining GHC's current maturity and the strategic importance of the roadmap.

Response To TASK 5: Governance Maturity Assessment and Roadmap

To: Board of Directors, GlobalHealth Connect (GHC)

From: Director of Information Security Governance / CISO

Date: September 11, 2026

Subject: Task 5 Submission; Information Security Governance Maturity Assessment and 12–18 Month Improvement Roadmap

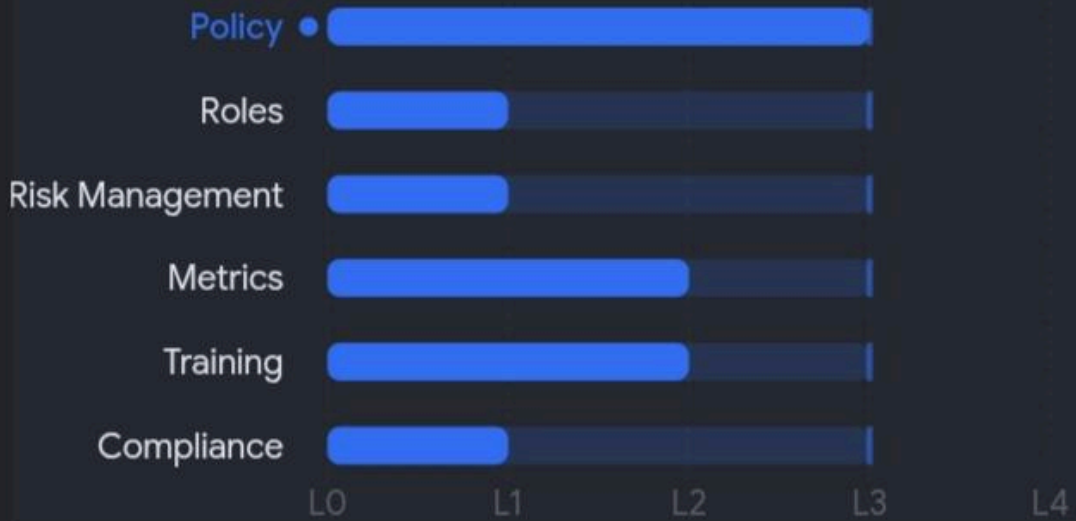
1. Executive Summary to the Board

GlobalHealth Connect's current information security governance posture sits at a Maturity Level 1 (Ad Hoc / Initial) across all six core domains. Following our rapid expansion and recent company acquisitions, security practices across GHC remain predominantly reactive, fragmented, and heavily reliant on individual employee effort rather than standardized corporate processes. While technical security controls exist, the lack of documented policies, unclear accountabilities, and informal risk management leave GHC exposed to significant operational disruptions, regulatory non-compliance under HIPAA and GDPR, and repeating data-leakage incidents.

The proposed 12–18 month Governance Improvement Roadmap is a strategic necessity to transform GHC's security posture from an ad-hoc, reactive state into a Level 3 (Defined) framework. Achieving a Defined maturity level ensures that security policies, risk management protocols, and regulatory compliance practices are fully institutionalized, continuously monitored, and aligned with GHC's business growth goals. This roadmap establishes the operational foundation required to safeguard patient trust, protect executive leadership, and support safe business expansion.

2. Current State Governance Maturity Assessment

Current Level Target Level



Avg Current
1.7

Avg Target
3.0

Remaining Gap
1.3

View Filter

All Domains

Action Required

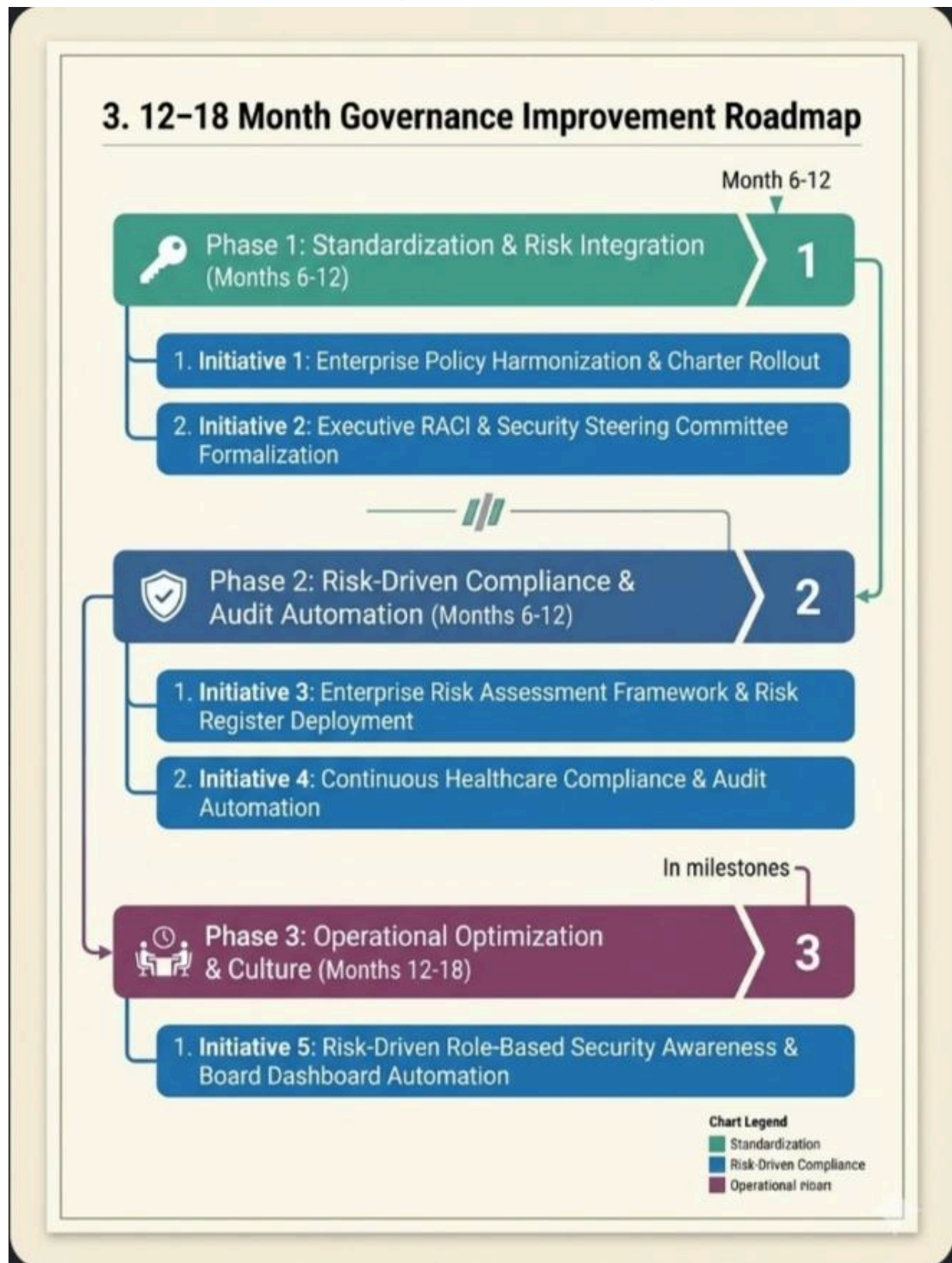
Interactive Asse...

Policy



Level 3

3. 12–18 Month Governance Improvement Roadmap



Priority Initiative 1: Policy Framework Harmonization and Life Cycle Governance

- Target Domains: Policy & Documentation | Compliance
- Objective: Establish a single, standardized, enterprise-wide security policy framework that replaces legacy acquisition policies and aligns with ISO/IEC 27001 and HIPAA security standards.
- Key Activities:
 - Conduct a gap analysis of all existing GHC and acquired subsidiary policies.
 - Draft, approve, and publish core security policies (Access Control, Incident Response, Data Protection, Patch Management).
 - Deploy a centralized GRC document portal with mandatory annual employee policy attestations.
- Measurable Expected Outcome: 100% of GHC departments and subsidiaries operate under a single, approved policy framework with 95%+ employee attestation within 6 months.

Priority Initiative 2: Enterprise Risk Assessment Framework and Risk Register

Deployment

- Target Domains: Risk Management | Metrics & Reporting
- Objective: Transition GHC from reactive incident management to a proactive, standardized risk assessment process.
- Key Activities:
 - Implement an enterprise Cyber Risk Register utilizing standardized risk scoring (FAIR / NIST SP 800-30).
 - Conduct quarterly threat assessments across all cloud environments and third-party vendor integrations.
 - Integrate high risk exception workflows into the Security Steering Committee approval process.
- Measurable Expected Outcome: 100% of identified critical assets and acquisition environments logged in a centralized Risk Register with formal risk treatment plans approved by the SSC.

Priority Initiative 3: Cross Functional RACI & Steering Committee Institutionalization

- Target Domains: Roles & Responsibilities | Policy & Documentation
- Objective: Formalize security accountabilities across all corporate levels and operational business units.
- Key Activities:
 - Operationalize the Security Steering Committee (SSC) with monthly meeting cadences.
 - Publish and enforce department-specific RACI charts for IT Operations, Software Engineering, HR, and Legal.
 - Tie business unit manager annual reviews to security policy compliance and SLA performance.
- Measurable Expected Outcome: 100% attendance quorum maintained across monthly SSC meetings and zero unassigned security responsibilities across operational workflows.

Priority Initiative 4: Role Based Security Awareness and Phishing Simulation Program

- Target Domains: Training & Awareness | Risk Management
- Objective: Transform workforce security behavior from passive compliance to an active line of defense.
- Key Activities:
 - Replace static annual training slides with interactive, role-based quarterly modules (e.g., specialized training for clinical engineers versus finance staff).
 - Launch monthly automated phishing simulation campaigns to test workforce readiness.
 - Implement automated follow up training for users who fail phishing simulations.
- Measurable Expected Outcome: Increase quarterly security training completion to 95% and reduce employee phishing simulation click rates from 20% down to less than 5%.

Priority Initiative 5: Automated Board Reporting & Continuous Compliance Monitoring

- Target Domains: Metrics & Reporting | Compliance
- Objective: Shift compliance monitoring from an ad-hoc audit scramble to continuous, automated executive visibility.
- Key Activities:
 - Implement automated metric collection tools for technical controls (Patch MTTR, Incident Mean Time to Detect/Contain).
 - Establish continuous HIPAA/GDPR compliance monitoring dashboards across all cloud environments.
 - Formalize quarterly Board Audit and Risk Committee reporting using the approved Board Executive Dashboard.
- Measurable Expected Outcome: Automated generation of quarterly Board security reports and 100% real time tracking of HIPAA/GDPR mandatory compliance controls.